

Área de Conocimiento de Tecnología de la Información y Comunicación

Auditoria de Sistemas

Software o herramientas para auditoria de redes, Sistemas de información y metodologías, estándares y normas para realizar la auditoria de seguridad

Elaborado por:

Br. Gerson Antonio
Valdivia

Br. Haxell Antonio
Trejos Rodríguez

Br. Alison Michelle
Navarro Goussen

Br. Stephanie Lucía
Mora Chávez

Br. Arleth del Rosario
Velásquez Gómez

Docente:

Msc. Leonel Antonio Martínez Zuniga

10 de mayo, 2026
Managua, Nicaragua

1. Investigar sobre software o herramientas para realizar auditoria de redes

Categoría 1: Software para realizar auditoria de redes

1. Nmap (Mapeo y Descubrimiento)

Se usa para descubrir qué hay vivo en una red y qué puertos están abiertos.

- **Modo de uso:**
 1. Conectar la laptop a la red del cliente (o segmento a auditar).
 2. Ejecutar un escaneo de descubrimiento para ver qué IPs están activas:
`nmap -sn 192.168.1.0/24`
 3. Ejecutar un escaneo profundo sobre equipos críticos buscando versiones de software: `nmap -sV -p- 192.168.1.50`
 4. Exportar los resultados a XML para cruzarlos con el inventario del cliente.
- **Cómo conseguirlo:** Es Open Source.
- **Enlace:** nmap.org/download

2. Tenable Nessus Professional (Escaneo de Vulnerabilidades)

Utilizado para probar los movimientos laterales y vulnerabilidades del sistema.

- **Modo de uso:**
 1. Instalar Nessus y actualizar los plugins (firmas de vulnerabilidades).
 2. Crear un "New Scan" usando la plantilla "Advanced Network Scan" o "Credentialed Patch Audit".
 3. Ingresar el rango de IPs a auditar
 4. Ingresar credenciales de administrador para que Nessus revise configuraciones internas.
 5. Ejecutar y exportar el reporte en PDF/CSV para la matriz de riesgos.
- **Cómo conseguirlo:** Software comercial. Existe **Nessus Essentials** que es gratuito para uso personal/educativo (limita el escaneo a 16 IPs).
- **Enlace:** tenable.com/products/nessus

3. Kali Linux (Suite de Pentesting Inalámbrico)

Sistema operativo que contiene cientos de herramientas (Aircrack-ng, Kismet) para auditar la seguridad WiFi y de red.

- **Modo de uso:**
 1. Arrancar Kali Linux (desde USB o Máquina Virtual).
 2. Conectar un adaptador WiFi externo que soporte "Modo Monitor" e inyección de paquetes (ej. Alfa Network).
 3. Poner la tarjeta en modo monitor: `airmon-ng start wlan0`.

4. Escanear redes cercanas: airodump-ng wlan0mon.
 5. Capturar el "Handshake" (el apretón de manos encriptado) obligando a un usuario a reconectarse.
 6. Intentar crackear el hash capturado para validar si la contraseña corporativa es débil.
- **Cómo conseguirlo:** Open Source (Gratis).
 - **Enlace:** kali.org/get-kali

4. Paessler PRTG Network Monitor (Monitoreo SNMP)

Usado para revisar la salud de los switches (CPU, RAM, temperatura) de forma histórica.

- **Modo de uso:**
 1. Instalar PRTG en un servidor o PC dentro de la red.
 2. Configurar "Sensores" apuntando a las IPs de los switches usando el protocolo SNMP (se necesita la comunidad SNMP del cliente).
 3. Dejar corriendo la herramienta por 48 horas.
 4. Analizar los gráficos generados para identificar picos de CPU o caídas de puertos.
- **Cómo conseguirlo:** Tienen una versión de prueba gratuita de 30 días con sensores ilimitados. Pasado el tiempo, es gratis hasta 100 sensores.
- **Enlace:** paessler.com/prtg

5. SolarWinds Network Performance Monitor - NPM (Tráfico y Broadcast)

- **Modo de uso:**
 1. Instalar la plataforma y configurar un puerto SPAN (Port Mirroring) en el switch principal del cliente.
 2. Conectar el servidor de SolarWinds a ese puerto para que "escuche" todo el tráfico.
 3. Analizar el dashboard de "Network Traffic" para ver el porcentaje de paquetes Broadcast vs Unicast.
- **Cómo conseguirlo:** Software Enterprise. Tienen una prueba gratuita (Free Trial) de 30 días, muy funcional para una auditoría corta.
- **Enlace:** solarwinds.com/network-performance-monitor

Categoría 2: Herramientas Híbridas (Software que requiere Hardware)

6. Ekahau Pro + Ekahau Sidekick (Mapas de Calor WiFi)

Es el estándar de la industria para diseño y auditoría WiFi.

- **Modo de uso:**

1. Cargar los planos arquitectónicos del edificio en Ekahau Pro.
 2. Conectar el Ekahau Sidekick (un hardware que se coloca en el hombro, con analizadores de espectro precisos) a la laptop o iPad.
 3. Caminar físicamente por toda la instalación haciendo clic en el plano para marcar la posición (Site Survey).
 4. El software genera un mapa de calor en tiempo real mostrando zonas muertas, interferencias (microondas, bluetooth) y potencias (ej. -67 dBm).
- **Cómo conseguirlo:** El software requiere licencia y el hardware Sidekick cuesta alrededor de \$3,000 - \$4,000 USD.
 - **Enlace:** ekahau.com

7. IxChariot de Keysight (Generación de Tráfico Sintético)

- **Modo de uso:**
 1. Instalar la consola de IxChariot en una PC.
 2. Instalar Endpoints en servidores o PCs en diferentes VLANs.
 3. Programar una prueba inyectando ráfagas de tráfico TCP/UDP masivo entre los Endpoints.
 4. Medir si el switch soporta la carga o si comienza a descartar paquetes.
- **Cómo conseguirlo:** Software Enterprise de alto costo. Requiere contactar a Keysight para una demostración o prueba de concepto (PoC).
- **Enlace:** keysight.com

Categoría 3: Equipamiento Especializado de Hardware Físico

8. Fluke Networks DSX-8000 (Certificador de Cableado)

- **Uso:** Un equipo principal se conecta a un extremo del cable (ej. el patch panel en el rack) y un equipo remoto se conecta a la roseta del usuario. Se presiona "Test". El equipo envía pulsos eléctricos a altas frecuencias y en 8 segundos te dice "PASS" o "FAIL" midiendo diafonía, longitud y resistencia.
- **Adquisición:** Equipo físico (Costo aprox. \$12,000 - \$18,000 USD).

9. NetAlly EtherScope nXG (Analizador de Red de Bolsillo)

- **Uso:** Es un dispositivo móvil con puertos Ethernet de fibra y cobre. El auditor lo conecta directamente a un puerto de pared dudoso. El equipo hace autonegociación en capa física, solicita DHCP, hace pings a servidores internos y comprueba conectividad a Internet. Demuestra irrefutablemente si el problema es el cable/switch o si es la PC del usuario.
- **Adquisición:** Equipo físico (Costo aprox. \$8,000+ USD).

10. Fluke 430 Series II (Analizador de Calidad de Energía para UPS)

- **Uso:** Se usan pinzas amperimétricas y sondas de voltaje directamente en el tablero eléctrico o a la salida de las UPS que alimentan los switches. Mide perturbaciones, picos y armónicos que podrían estar reiniciando los switches de forma silenciosa.
- **Adquisición:** Equipo físico.

11. Cámara Termográfica (Fluke Ti400)

- **Uso:** El auditor se para frente al rack de telecomunicaciones, apunta la cámara a los switches y servidores, y toma una foto térmica. Si un módulo SFP (transceptor de fibra) o la fuente de poder del switch brilla en blanco/rojo intenso, hay un problema de disipación o falla inminente.
- **Adquisición:** Equipo físico.

12. NetBotz (Sensores Ambientales de APC/Schneider)

- **Uso:** Pequeños dispositivos físicos que se atornillan en el cuarto de servidores (MDF/IDF). Tienen sondas de temperatura, humedad e incluso sensores de líquidos en el suelo. Se conectan a la red y envían alertas SNMP/Email si el aire acondicionado falla.
- **Adquisición:** Hardware corporativo (se compra vía distribuidores de APC).

2. Investigar sobre software o herramientas para realizar auditoria de sistemas de información

Categoría 1: Software para Auditoría de Sistemas

1. ACL Analytics (Análisis de Datos Masivos - CAATs) Es la herramienta por excelencia para la extracción y análisis de millones de registros en bases de datos para auditar transacciones financieras, operativas y detectar fraudes.

- **Modo de uso:**
 - Importar tablas de datos directamente desde el ERP del cliente (SAP, Oracle) o archivos planos (CSV, Excel).
 - Perfilar y sanear los datos para verificar su integridad (identificar celdas vacías o formatos incorrectos).
 - Ejecutar scripts y funciones analíticas integradas (ej. analizar la Ley de Benford, buscar pagos duplicados o facturas en fines de semana).
 - Exportar los hallazgos y evidencias a un reporte estructurado.
- **Cómo conseguirlo:** Software comercial de pago. Requiere licenciamiento anual corporativo.
- **Enlace:** [diligent.com/solutions/audit](https://www.diligent.com/solutions/audit)

2. Splunk Enterprise (Auditoría de Logs y Monitoreo SIEM) Utilizado para correlacionar y analizar los registros de actividad (logs) de todos los servidores y aplicaciones, permitiendo auditar quién hizo qué, y cuándo.

- **Modo de uso:**
 - Integrar las fuentes de logs de los sistemas críticos (bases de datos, servidores Windows/Linux, aplicaciones).
 - Diseñar y ejecutar consultas de búsqueda utilizando el lenguaje SPL (Search Processing Language) para rastrear eventos específicos.
 - Auditar intentos de inicio de sesión fallidos, accesos fuera de horario laboral o escalado de privilegios no autorizados.
 - Configurar tableros (dashboards) de cumplimiento para demostrar la retención y revisión de logs.

- **Cómo conseguirlo:** Software comercial Enterprise. Existe una versión Splunk Free limitada a la indexación de 500 MB de datos por día (ideal para pruebas o sistemas pequeños).
- **Enlace:** splunk.com

3. Burp Suite Professional (Auditoría de Aplicaciones Web) La plataforma estándar de la industria para evaluar la seguridad y los controles lógicos de aplicaciones web, portales transaccionales y APIs.

- **Modo de uso:**
 - Configurar Burp Suite como un proxy local e indicarle al navegador que todo el tráfico pase por ahí.
 - Navegar por la aplicación del cliente simulando el comportamiento de un usuario normal (interceptando el tráfico HTTP/S).
 - Utilizar el módulo "Scanner" para buscar vulnerabilidades automáticas (OWASP Top 10).
 - Usar el módulo "Intruder" para inyectar cargas útiles (SQL Injection, Cross-Site Scripting) y validar si los controles de validación de datos funcionan.
- **Cómo conseguirlo:** Comercial (Versión Professional). Existe una versión gratuita llamada Burp Suite Community Edition (sin el escáner automatizado).
- **Enlace:** portswigger.net/burp

4. SailPoint IdentityIQ (Auditoría de Accesos e Identidades) Plataforma utilizada para la gobernanza de identidades, vital para auditar la Segregación de Funciones (SoD) y validar los controles de acceso lógico.

- **Modo de uso:**
 - Conectar la herramienta con los directorios de usuarios (Active Directory) y el sistema de Recursos Humanos.
 - Mapear las matrices de Segregación de Funciones (SoD) para asegurar que, por ejemplo, quien aprueba compras no pueda crear proveedores.
 - Ejecutar "Campañas de Certificación", automatizando el envío de correos a los gerentes para que aprueben o revoquen los accesos actuales de su equipo.
 - Generar reportes de cuentas huérfanas o accesos sobre-privilegiados.

- **Cómo conseguirlo:** Software Enterprise corporativo. Requiere implementación y licenciamiento directo.
- **Enlace:** sailpoint.com

Categoría 2: Plataformas GRC y Herramientas Híbridas (Plataformas de Gobernanza y Configuración)

5. ServiceNow GRC / IRM (Gestión de Riesgos y Cumplimiento) Orquesta todo el ciclo de vida de la auditoría de TI, centralizando las políticas, los riesgos, los controles y las evidencias en un solo lugar.

- **Modo de uso:**
 - Cargar el marco normativo a auditar (ej. ISO 27001, SOX ITGC, COBIT).
 - Vincular los objetivos de control con los activos de información (servidores, bases de datos) del inventario (CMDB).
 - Asignar tareas automatizadas a los dueños de los sistemas para que suban la evidencia requerida (capturas de pantalla, políticas firmadas).
 - Revisar la evidencia dentro de la plataforma y marcar el control como "Efectivo" o "Inefectivo", generando un panel de control para la gerencia.
- **Cómo conseguirlo:** Plataforma SaaS (Software as a Service) Enterprise. Requiere agendar una demostración comercial; su costo varía por módulos y usuarios.
- **Enlace:** servicenow.com/products/governance-risk-and-compliance.html

6. Titania Nipper (Auditoría de Configuraciones de Sistemas/Red) Herramienta que analiza el código fuente de los archivos de configuración sin necesidad de interactuar o escanear la red de producción.

- **Modo de uso:**
 - Solicitar al administrador del sistema la exportación del archivo de configuración del firewall, enrutador o switch central (en formato de texto).
 - Importar el archivo de configuración en la plataforma Nipper.
 - Seleccionar el estándar de cumplimiento contra el cual se quiere auditar (ej. CIS Benchmarks, STIGs, PCI-DSS).

- Generar un informe que detalla configuraciones riesgosas (contraseñas débiles, protocolos en texto claro, reglas permisivas) y sus recomendaciones de parcheo.
- **Cómo conseguirlo:** Software comercial. Permiten descargar una versión de prueba gratuita (Trial) completamente funcional por un tiempo limitado.
- **Enlace:** titania.com/products/nipper/

Categoría 3: Equipamiento Especializado de Hardware (Validación Física de Sistemas)

7. Proxmark3 (Auditoría de Control de Acceso Físico a Data Centers)

- **Uso:** Es un dispositivo de investigación RFID. El auditor lo utiliza en evaluaciones de seguridad física (Red Teaming) para intentar leer, interceptar o clonar las tarjetas de acceso (fotochecks) de los empleados. Permite validar si los sistemas de control de acceso al Centro de Datos utilizan cifrado fuerte o si son vulnerables a clonación mediante proximidad.
- **Adquisición:** Se puede comprar en kits a través de distribuidores de seguridad electrónica (Costo aprox. \$100 - \$350 USD dependiendo de la versión y antenas).

8. YubiKey 5 FIPS Series (Validación de Controles Criptográficos y MFA)

- **Uso:** Dispositivos de hardware criptográfico (tokens USB/NFC) utilizados por los auditores para probar la resiliencia de la Autenticación Multifactor (MFA). Se evalúa si los sistemas críticos de la empresa (ERP, VPN, servidores en la nube) soportan e imponen el uso de hardware tokens (FIDO2/WebAuthn) para prevenir ataques de phishing que el SMS o las apps de autenticación no pueden detener.
- **Adquisición:** Hardware físico comercial. Se compra directamente al fabricante Yubico o a través de revendedores corporativos (Costo aprox. \$50 - \$100 USD por llave).

3. Auditoría de seguridad.

1. Metodologías

A. ITAF (Information Technology Assurance Framework) de ISACA

Es la metodología global para la práctica de la auditoría de sistemas. Se divide en fases clave:

- **Fase de Planificación:** Involucra el entendimiento del negocio, la evaluación inicial de riesgos (Risk Assessment) y la definición del alcance. Aquí se decide qué procesos críticos se van a auditar.
- **Fase de Ejecución (Trabajo de Campo):** Recopilación de evidencias, entrevistas, observación de procesos y validación de los controles de seguridad contra un estándar de referencia.
- **Fase de Elaboración de Informes:** Estructuración de los hallazgos. ITAF exige que todo hallazgo contenga: *Condición* (lo que se encontró), *Criterio* (la norma incumplida), *Causa* (por qué falló) y *Efecto* (el riesgo para el negocio).
- **Fase de Seguimiento:** Verificación de que la gerencia ha implementado las acciones correctivas prometidas.

B. OSSTMM (Open Source Security Testing Methodology Manual)

Cuando la auditoría de seguridad incluye pruebas técnicas operacionales (como un *Ethical Hacking* formal), OSSTMM es la metodología científica a seguir.

- Se centra en medir la superficie de ataque verificable de manera empírica, sin suposiciones.
- Divide la auditoría en canales: Seguridad Física, Seguridad Humana (Ingeniería Social), Seguridad Inalámbrica, Telecomunicaciones y Redes de Datos.

C. Metodología basada en Riesgos (Risk-Based Auditing)

El enfoque moderno exige que la auditoría no sea un simple "checklist". La metodología basada en riesgos implica que los esfuerzos del auditor se concentren exclusiva y proporcionalmente en las áreas que representan el mayor riesgo financiero, operativo o reputacional para la organización.

2. Estándares

A. COBIT 2019 (Control Objectives for Information and Related Technologies)

Es el estándar supremo para el **Gobierno y la Gestión de las TI**.

- **Enfoque de Auditoría:** El auditor usa COBIT para evaluar si la tecnología está alineada con las metas de la empresa.
- Evalúa aspectos como la correcta segregación de funciones, la gestión del riesgo tecnológico, la optimización de recursos y la transparencia en la entrega de valor de TI.
- Define niveles de capacidad y madurez (del 0 al 5) para cada proceso de TI, permitiendo al auditor cuantificar qué tan maduro es el departamento de sistemas de la empresa.

B. NIST Cybersecurity Framework (CSF) 2.0

Desarrollado por el Instituto Nacional de Estándares y Tecnología (EE. UU.), es el lenguaje universal para gestionar el riesgo de ciberseguridad.

- **Enfoque de Auditoría:** Permite evaluar la postura de seguridad de la organización basándose en seis funciones principales:
 1. **Gobernar:** ¿Existen políticas y liderazgo en seguridad?
 2. **Identificar:** ¿Conoce la empresa qué activos (datos, equipos) tiene y sus riesgos?
 3. **Proteger:** ¿Están implementados los controles de acceso y el cifrado?
 4. **Detectar:** ¿Puede la empresa darse cuenta si está siendo atacada en tiempo real?
 5. **Responder:** ¿Existe un plan de acción para contener un incidente?
 6. **Recuperar:** ¿Están probados los respaldos y la continuidad del negocio?

C. Controles CIS (Center for Internet Security)

Son un conjunto priorizado de acciones defensivas. El auditor los utiliza para evaluar la "higiene técnica" básica de la organización. Un auditor verificará si la empresa cumple con los grupos de implementación básicos, como el inventario de hardware/software, la gestión de vulnerabilidades y el control de privilegios administrativos.

3. Normas

A. ISO/IEC 27001 (Sistema de Gestión de Seguridad de la Información - SGSI)

Es la norma certificable internacional. El auditor evalúa el cumplimiento de sus cláusulas obligatorias, verificando que la empresa implemente un ciclo de mejora continua (Planificar, Hacer, Verificar, Actuar) orientado a proteger la Confidencialidad, Integridad y Disponibilidad de la información.

- El auditor revisará la **Declaración de Aplicabilidad (SoA)**, un documento crítico donde la empresa justifica qué controles del anexo A de la norma ISO 27002 ha implementado y cuáles ha excluido.

B. Regulaciones Fiscales y Gubernamentales Locales

Las operaciones informáticas financieras están sujetas a normas técnicas dictadas por los entes reguladores de cada país.

- **Enfoque de Auditoría:** El auditor informático debe garantizar que los sistemas ERP o plataformas contables cumplan con las disposiciones técnicas de entidades como la DGI en Nicaragua. Esto incluye verificar que los sistemas aseguren la inalterabilidad de los registros contables, la trazabilidad de las anulaciones y la seguridad en la emisión de la factura electrónica.

C. PCI-DSS (Payment Card Industry Data Security Standard)

Norma obligatoria para cualquier comercio, banco o pasarela de pagos que procese, almacene o transmita datos de tarjetas de crédito.

- **Enfoque de Auditoría:** Es una de las normas más prescriptivas y estrictas. El auditor verifica 12 requerimientos fundamentales, exigiendo pruebas sólidas de segmentación de redes, políticas de retención de datos estrictas, pruebas de penetración anuales obligatorias y criptografía robusta.